Análisis de Incidente de Seguridad en Entorno Linux (Simulación SOC)

19/04/2026

Samuel Calderón Candela

Analista de seguridad

Entorno:

- **Máquina atacante:** Kali Linux
- **Máquina víctima:** Ubuntu Server 24.04
- **Red:** Entorno virtual controlado

Descripción del entorno

El análisis se realizó en un entorno controlado de laboratorio diseñado para simular un incidente real de seguridad informática.

La infraestructura consistió en dos máquinas virtuales dentro de una red interna:

- Una máquina atacante con sistema operativo Kali Linux, utilizada para simular actividades maliciosas como intentos de acceso no autorizado y establecimiento de comunicación remota.
- Una máquina víctima con sistema operativo Ubuntu Server 24.04, configurada con el servicio SSH activo (OpenSSH Server), representando un servidor expuesto a la red.

Ambas máquinas se encontraban en la misma red virtual, permitiendo la comunicación directa entre ellas. Este entorno facilitó la simulación de un escenario realista de compromiso, incluyendo acceso remoto, ejecución de código y establecimiento de un canal de comando y control (C2).

LÍNEA DE TIEMPO DEL INCIDENTE

El incidente se desarrolló en múltiples fases, las cuales fueron identificadas mediante el análisis de logs, procesos y conexiones de red.

1. Acceso inicial (Intentos de autenticación SSH):
   Se detectaron múltiples intentos fallidos de autenticación a través del servicio SSH, indicando un posible ataque de fuerza bruta dirigido al servidor. Posteriormente, se registró un acceso exitoso desde la misma dirección IP, confirmando el compromiso de credenciales válidas.

2. Establecimiento de acceso remoto:
   Tras el acceso exitoso, el atacante obtuvo una sesión en el sistema, desde la cual realizó actividades posteriores. Se evidenció el uso de privilegios elevados, lo que permitió un control completo del sistema.

3. Ejecución de código malicioso:
   El atacante creó y ejecutó un script en Python ubicado en la ruta /tmp/update.py. Esta ubicación es comúnmente utilizada para almacenar archivos temporales y es frecuentemente abusada para ocultar artefactos maliciosos.

4. Establecimiento de canal Command and Control (C2):
   El script ejecutado estableció una conexión saliente desde la máquina víctima hacia la máquina atacante a través del puerto 4444, generando un canal de comunicación remoto que permitió la ejecución de comandos desde el sistema atacante.

5. Ejecución remota de comandos:
   A través del canal C2, el atacante pudo ejecutar comandos en la máquina comprometida, manteniendo control sobre el sistema de forma remota.

6. Acceso a información sensible (Exfiltración):
   Se identificó el acceso a un archivo ubicado en /tmp/contrasenias.txt, el cual contenía información simulada de tipo sensible. Este acceso fue realizado mediante comandos ejecutados remotamente, evidenciando la capacidad del atacante para consultar y potencialmente extraer datos del sistema comprometido.

Evidencias técnicas

Durante el análisis del incidente se recolectaron diversas evidencias técnicas que permitieron validar cada fase del ataque.

1. Registros de autenticación SSH:

Se analizaron los logs del servicio SSH mediante el comando journalctl -u ssh, identificando múltiples intentos fallidos de autenticación seguidos de un acceso exitoso desde la dirección IP de la máquina atacante.

Estos eventos confirman un posible ataque de fuerza bruta y posterior compromiso de credenciales válidas.

```
root@scc:~# journalctl -u ssh | grep -E "Failed|Accepted"
Apr 19 23:37:29 scc sshd[2030]: Failed password for scc from 192.168.1.21 port 60830 ssh2
Apr 19 23:37:35 scc sshd[2030]: Failed password for scc from 192.168.1.21 port 60830 ssh2
Apr 19 23:37:42 scc sshd[2030]: Failed password for scc from 192.168.1.21 port 60830 ssh2
Apr 20 00:00:35 scc sshd[2199]: Accepted password for scc from 192.168.1.21 port 57942 ssh2
Apr 20 00:43:12 scc sshd[2423]: Accepted password for scc from 192.168.1.21 port 37718 ssh2
Apr 20 01:05:28 scc sshd[2604]: Accepted password for scc from 192.168.1.21 port 42970 ssh2
root@scc:~# _
```

2. Ejecución de proceso sospechoso:

Mediante el uso de herramientas de monitoreo de procesos (ps aux), se identificó la ejecución de un proceso asociado a python3 ejecutando el archivo /tmp/update.py.

La ubicación del archivo y el tipo de ejecución son consistentes con comportamiento malicioso, ya que /tmp es comúnmente utilizado para ocultar artefactos temporales o no persistentes.

```
root@scc:~# ps aux | grep update.py
root        2322  0.0  0.2   7720  4788 pts/1    S+   00:14   0:00 nano /tmp/update.py
root        2738  0.0  0.5  18160 11412 pts/5    S+   01:20   0:00 python3 /tmp/update.py
root        2820  0.0  0.1   6680  2360 pts/2    S+   01:50   0:00 grep --color=auto update.py
root@scc:~# ls -la /tmp
total 60
drwxrwxrwt 14 root root 4096 Apr 20 00:53 .
drwxr-xr-x 23 root root 4096 Apr 19 22:56 ..
drwxrwxrwt  2 root root 4096 Apr 19 23:02 .font-unix
drwxrwxrwt  2 root root 4096 Apr 19 23:02 .ICE-unix
drwx------  2 root root 4096 Apr 19 23:02 snap-private-tmp
drwx------  3 root root 4096 Apr 20 00:25 systemd-private-c9cd2f6d285c4c19a729ef2e06455880-fwupd.service-CJP6gq
drwx------  3 root root 4096 Apr 19 23:02 systemd-private-c9cd2f6d285c4c19a729ef2e06455880-ModemManager.service-G5L4Up
drwx------  3 root root 4096 Apr 19 23:02 systemd-private-c9cd2f6d285c4c19a729ef2e06455880-polkit.service-W3yQKU
drwx------  3 root root 4096 Apr 19 23:02 systemd-private-c9cd2f6d285c4c19a729ef2e06455880-systemd-logind.service-YjGS7X
drwx------  3 root root 4096 Apr 19 23:02 systemd-private-c9cd2f6d285c4c19a729ef2e06455880-systemd-resolved.service-gz7cQJ
drwx------  3 root root 4096 Apr 19 23:02 systemd-private-c9cd2f6d285c4c19a729ef2e06455880-systemd-timesyncd.service-U2FU22
drwx------  3 root root 4096 Apr 20 00:25 systemd-private-c9cd2f6d285c4c19a729ef2e06455880-upower.service-XAiAZH
-rw-r--r--  1 root root  143 Apr 20 00:53 update.py
drwxrwxrwt  2 root root 4096 Apr 19 23:02 .X11-unix
drwxrwxrwt  2 root root 4096 Apr 19 23:02 .XIM-unix
root@scc:~#
```

A través del comando ss -tnp, se detectó una conexión TCP establecida desde la máquina víctima hacia la dirección IP de la máquina atacante en el puerto 4444.

Esta conexión estaba asociada directamente al proceso python3, evidenciando la existencia de un canal de comunicación tipo Command and Control (C2).

```
root@scc:~# ss -tnp
State      Recv-Q     Send-Q       Local Address:Port        Peer Address:Port      Process
ESTAB      0          0             192.168.1.23:22          192.168.1.21:57942      users:(("sshd",pid=2254,fd=4),("sshd",pid=2199,fd=4))
ESTAB      0          0             192.168.1.23:45418       192.168.1.21:4444       users:(("python3",pid=2738,fd=3))
ESTAB      0          0             192.168.1.23:22          192.168.1.21:42970      users:(("sshd",pid=2660,fd=4),("sshd",pid=2604,fd=4))
root@scc:~#
```

4. Evidencia de acceso a información:

Se confirmó el acceso al archivo /tmp/contrasenias.txt mediante ejecución de comandos remotos a través del canal C2, lo cual demuestra la capacidad del atacante para interactuar con el sistema y consultar información almacenada en él.

```
Session  Acciones  Editar  Vista  Ayuda
contrasenias.txt  vboxpostinstall.sh
cat: contraseñas.txt: No such file or directory
ID : 12233 PASSWORD: samsec1242
ID : 4532  PASSWORD: shfgd1555
ID : 23131 PASSWORD: sample555
```

```
Session  Acciones  Editar  Vista  Ayuda
┌──(scc㉿kali)-[~]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.1.21] from (UNKNOWN) [192.168.1.23] 45418
pwd
cd /home/scc
ls -l
ls
pwd
cd --
pwd
cat /home/scc clientes.txt
cd/
cd /
ls
clear
ls
cat contraseñas.txt
cat contrasenias.txt
```

Perspectiva del atacante.

Indicadores de compromiso (IoC)

A partir del análisis realizado, se identificaron los siguientes Indicadores de Compromiso (IoC), los cuales pueden ser utilizados para la detección de actividades similares en otros sistemas:

- Dirección IP sospechosa:
  Se identificó la dirección IP de la máquina atacante como origen de los intentos de autenticación y del establecimiento del canal C2.
- Puerto de comunicación no estándar:
  Se detectó el uso del puerto 4444 para la comunicación remota, lo cual no corresponde a servicios legítimos del sistema y puede ser considerado sospechoso.
- Proceso inusual:
  Ejecución del proceso python3 asociado a un script ubicado en /tmp, comportamiento no habitual en un entorno de servidor.
- Archivo sospechoso:
  Presencia del archivo /tmp/update.py, utilizado para establecer una conexión remota y ejecutar comandos en el sistema.
- Archivo de datos potencialmente comprometido:
  Archivo /tmp/clientes.txt, accedido durante la sesión remota, que contiene información sensible simulada.
- Conexión saliente sospechosa:
  Tráfico de red desde la máquina víctima hacia una dirección IP externa en un puerto no estándar, asociado al proceso identificado.

Estos indicadores permiten identificar patrones de comportamiento malicioso y pueden ser utilizados para la creación de reglas de detección y monitoreo en herramientas de seguridad.

Análisis de incidente

El incidente analizado evidencia una cadena de compromiso típica en entornos Linux expuestos a servicios remotos sin controles de seguridad adecuados.

El acceso inicial fue posible debido a la falta de mecanismos de protección en el servicio SSH, permitiendo múltiples intentos de autenticación sin restricciones. La ausencia de medidas como limitación de intentos, autenticación multifactor o monitoreo activo facilitó el compromiso de credenciales válidas.

Una vez dentro del sistema, el atacante logró ejecutar código sin restricciones, lo que indica deficiencias en el control de ejecución y monitoreo de actividades en el host. La utilización del directorio /tmp para alojar el script malicioso demuestra el aprovechamiento de ubicaciones comúnmente ignoradas en revisiones de seguridad.

El establecimiento de un canal de comunicación C2 hacia un puerto no estándar refleja la falta de control sobre conexiones salientes. La inexistencia de reglas de firewall o mecanismos de inspección de tráfico permitió que la comunicación remota se realizara sin ser detectada ni bloqueada.

Finalmente, el acceso a información sensible evidencia la ausencia de controles de acceso a datos y monitoreo de actividad sobre archivos críticos. Esto permitió al atacante interactuar libremente con el sistema y consultar información almacenada.

En conjunto, el incidente fue posible debido a la combinación de debilidades en autenticación, monitoreo, control de ejecución y gestión de tráfico de red, lo que permitió una progresión completa desde acceso inicial hasta exfiltración de información.

Recomendaciones de seguridad

Con base en el análisis realizado, se proponen las siguientes recomendaciones para mitigar riesgos y prevenir incidentes similares en el futuro:

1. Fortalecimiento del servicio SSH:
   Implementar mecanismos de protección como limitación de intentos de autenticación, uso de claves públicas en lugar de contraseñas, y deshabilitación del acceso directo como usuario root. Adicionalmente, se recomienda el uso de herramientas como Fail2Ban para bloquear direcciones IP con múltiples intentos fallidos.

2. Monitoreo y registro de eventos:
   Establecer monitoreo continuo de logs del sistema, especialmente del servicio SSH, para detectar comportamientos anómalos. Integrar estos registros en un sistema SIEM permitiría una correlación más efectiva y generación de alertas en tiempo real.

3. Control de ejecución de procesos:
   Implementar controles que permitan detectar y restringir la ejecución de scripts en ubicaciones no autorizadas como /tmp. El uso de herramientas

de seguridad en endpoint (EDR) facilitaría la detección de procesos sospechosos.

4. Restricción de conexiones salientes:
   Configurar reglas de firewall para limitar las conexiones salientes únicamente a servicios necesarios. Esto permitiría bloquear intentos de establecimiento de canales C2 hacia puertos no autorizados.

5. Protección de información sensible:
   Aplicar controles de acceso a archivos críticos y monitorear su uso. La implementación de auditoría sobre acceso a archivos permitiría detectar intentos de lectura no autorizados.

6. Concienciación y buenas prácticas:
   Promover el uso de contraseñas seguras y políticas de autenticación robustas. La formación en seguridad para administradores y usuarios reduce significativamente la probabilidad de compromisos exitosos.

Conclusiones

El incidente analizado demuestra cómo una combinación de configuraciones inseguras y ausencia de controles de monitoreo puede permitir el compromiso completo de un sistema.

A partir de un acceso inicial mediante el servicio SSH, el atacante logró ejecutar código malicioso, establecer un canal de comunicación remota y acceder a información sensible dentro del sistema. La progresión del ataque evidencia la importancia de implementar controles en cada etapa, desde la autenticación hasta la supervisión del tráfico de red y la ejecución de procesos.

El análisis realizado permitió identificar indicadores claros de compromiso y reconstruir la secuencia completa del ataque, destacando la relevancia de la correlación entre logs, procesos y conexiones de red en la detección de incidentes.

Este ejercicio refuerza la necesidad de adoptar un enfoque proactivo en seguridad, donde la prevención, detección y respuesta se integren de manera continua para reducir la superficie de ataque y el impacto de posibles amenazas.